

Name: Neha Gahalot

University: Central university of Jammu

Major: Computer Science

Internship duration: July 1st, 2025 – July 31st, 2025

Company: Shadow Fox

Domain: Cyber Security

Batch: JulyB1

Gmail: nehagahalot786@gmail.com

Task level: Beginner level

Task Level (Beginner)

Table of Content

S. No	Title
1	Find all the ports that are open on the website http://testphp.vulnweb.com/
2	Brute force the website http://testphp.vulnweb.com/ and find the directories that are present in the website.
3	Make a login in the website http://testphp.vulnweb.com/ and intercept the network traffic using wireshark and find the credentials that were transferred through the network

List of Figures

S. No	Name
1	Nmap scanning
2	Dirbuster/gobuster scanning
3	Log in attempt
4	Wireshark result

Introduction and information about the report and the machine

Task Level (Beginner)

Introduction:

The purpose of this activity is to analyze the network security of the target website by identifying its open ports and the services as potential entry points for attackers if not properly secured. By conducting a port scan, the goal was to understand the exposed network surface of the system and determine which services are publicly accessible.

The test was carried on the website

<http://testphp.vulnweb.com/>

Information about the report:

1. Port Scanning

This initial task was to check which ports on a targeted website are open and accepting connections. Every service on a sever, like a website uses a specific port number. By scanning all the ports, we can find out which services are running and if any of them could be a weak point that attackers might use.

2. Brute Forcing directories on website

The second task involved executing a brute force attack to list all the directories on the website. This method is used to find hidden or unlisted parts of a website, such as admin panels, backup files, or test folders. This helps security testers discover areas that may contain sensitive information or need better protection.

3. Network Traffic Interception

We executed, a network traffic interception by logging into the website and capturing network packets using Wireshark. It means capturing and looking at the data that is sent between two computers over a network. This enables us to examine the data being transmitted between the client and server, with the goal of identifying any credentials or sensitive information being sent in plaintext.

Required machine:

1. Standard computer system with network connectivity.
2. Linux operating system or Windows operating system

Task-1

Find all the ports that are open on the website

<http://testphpvulnweb.com/>

❖ **Attack name:** Port scanning

❖ **Severity:** High

Reason: Port 80 uses unencrypted HTTP, so any data sent between the client and the server could be intercepted by attackers. Attackers could carry out man-in-the-middle attacks, capture login credentials and manipulate content.

❖ **Steps to reproduce with screenshots**

Step 1: Target IP Identification

The first step is to confirm that the target website is active and reachable by using the ping command. It confirmed that the server was online. Then IP address of the website was identified using the nslookup command. This returned the IP address 44.228.249.3 which then used as the input for the nmap tool to perform a detailed port scan and discover open services.

Step 2: Port scanning using nmap

After identifying the target IP address, a port scan was carried out using nmap tool to find open ports and running services on the server.

Here are the results of the port scan:

- Target website: <http://testphp.vulnweb.com/>
- Target IP address: 44.228.249.3

- Nmap command: `nmap -sV 44.228.249.3`

Analysis: -

Port/Protocol	State	Service	Version
80/tcp	open	HTTP	nginx 1.90.0

Unencrypted HTTP traffic can be intercepted, and outdated server Ngnix version may have unknown vulnerabilities. To reduce the risk of vulnerabilities, regularly applying the most recent security patches to web servers is crucial.

Step3: Nmap scanning figure 1

```

neha-gahalot@neha-gahalot-VirtualBox: ~
neha-gahalot@neha-gahalot-VirtualBox:~$ nslookup testphp.vulnweb.com
Server:          127.0.0.53
Address:         127.0.0.53#53

Non-authoritative answer:
Name:   testphp.vulnweb.com
Address: 44.228.249.3

neha-gahalot@neha-gahalot-VirtualBox:~$ nmap 44.228.249.3
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-07-28 13:38 IST
Nmap scan report for ec2-44-228-249-3.us-west-2.compute.amazonaws.com (44.228.249.3)
Host is up (0.30s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 22.48 seconds
neha-gahalot@neha-gahalot-VirtualBox:~$ nmap -sV testphp.vulnweb.com
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-07-28 13:39 IST
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.29s latency).
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http      nginx 1.19.0

Service detection performed. Please report any incorrect results at https://nmap.org/submit
Nmap done: 1 IP address (1 host up) scanned in 38.65 seconds
neha-gahalot@neha-gahalot-VirtualBox:~$ nmap -p- testphp.vulnweb.com
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-07-28 13:41 IST
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.00016s latency).
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com

```

❖ **Impact:**

Advantages:

- 1.Helps discover which ports are open and accessible on the target. Knowing open ports and services guides deeper vulnerability testing.
- 2.Old browsers and some automated systems might rely on port 80 for accessing web resources.

Disadvantages:

- 1.Port 80 uses HTTP, which does not encrypt data. Sensitive information like login credentials can be intercepted by attackers.
- 2.The server runs Nginx 1.19.0, which may contain known vulnerabilities that can be exploited if not updated. The version of Nginx is visible in the scan, giving attackers specific details to plan targeted attacks

❖ **Mitigation steps:**

- 1.Upgrade from version 1.90.0 to the latest stable version to fix known vulnerabilities. Regularly monitor for security patches and apply updates promptly.
2. Redirect all HTTP traffic to HTTPS to ensure secure, encrypted communication.
3. Disable version banners in the Nginx configuration to prevent service version exposure. This reduces the risk of targeted attacks on known version vulnerabilities.

4. Perform routine port scans and vulnerability assessments to stay ahead of threats. Monitor logs for unusual activity or access attempts.

Resources used:

Linux operating system and network mapping(nmap).

Task-2

Brute force the website <http://testphp.vulnweb.com/> and find the directories that are present in the website.

❖ **Attack name:** Brute Forcing directories on website

❖ **Severity:** High

Reason: The severity is high because directories like admin, secured, vendor, and CVS often contain critical information and vulnerabilities that can be exploited to compromise the entire system.

❖ **Steps to reproduce with screen shots:**

Step 1: Target url:

Firstly, get the target webpage url, in my assessment the target url is <http://testphp.vulnweb.com>

Step 2 :Brute Forcing url:

Using dirbuster, the Linux commandline tool. Scan that url using tool and you will find all the hidden directories in that website. But here is the one catch, if you want to strong result then you need strong directory wordlist for scanning.

Here are the results of the scan:

1.Target website: <http://testphp.vulnweb.com>

2. Some, like /CVS/ and /secured/, may **pose a risk** if not properly restricted or cleaned up.

❖ **Analysis:**

Path	Status	What it means
/crossdomain.xml	200	File exists and is accessible
/CVS/Entries	200	CVS version control folder – potential sensitive info
/favicon.ico	200	Website icon (normal)
/index.php	200	Main webpage source file, confirmed present
/pictures/	301	Redirected folder – exists
/secured/	301	Protected or relocated directory
/vendor/	301	Possibly for backend dependencies – might reveal technologies if accessible
/cgi-bin/	403	Exists but access is forbidden – might hold dangerous scripts

Above all the directories and sub-directories we got in scanning. The most sever thing is in here, exposor of the admin, cvs, secured and vendor directories or database.

Step 3: gobuster scanning figure(2):

```
neha-gahalot@neha-gahalot-VirtualBox:~$ sudo gobuster dir -u http://on.txt
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://testphp.vulnweb.com
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/dirb/wordlists/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/admin (Status: 301) [Size: 169] [--> http://testphp.vulnweb.com/admin]
/cgi-bin (Status: 403) [Size: 276]
/cgi-bin/ (Status: 403) [Size: 276]
/crossdomain.xml (Status: 200) [Size: 224]
/CVS (Status: 301) [Size: 169] [--> http://testphp.vulnweb.com/CVS]
/CVS/Entries (Status: 200) [Size: 1]
/CVS/Repository (Status: 200) [Size: 8]
/CVS/Root (Status: 200) [Size: 1]
/favicon.ico (Status: 200) [Size: 894]
/images (Status: 301) [Size: 169] [--> http://testphp.vulnweb.com/images]
/index.php (Status: 200) [Size: 4958]
/pictures (Status: 301) [Size: 169] [--> http://testphp.vulnweb.com/pictures]
/secured (Status: 301) [Size: 169] [--> http://testphp.vulnweb.com/secured]
/vendor (Status: 301) [Size: 169] [--> http://testphp.vulnweb.com/vendor]
Progress: 4614 / 4615 (99.98%)
=====
Finished
```

Impact:

1. The scan revealed directories and files that are not publicly linked on the website, such as `/CVS/`, `/secured/`, and `/vendor/`. These could expose sensitive information like source code, credentials, or system structure.
2. The `/CVS/` entries suggest that version control folders are publicly accessible. This is a **critical misconfiguration** and may leak development history, usernames, or internal logic.
3. Files like `/index.php` and `/crossdomain.xml` are accessible. If not configured securely, they could be exploited by attackers to learn more about the backend system.
4. These discovered paths could serve as **entry points** for SQL injection, file upload vulnerabilities, LFI (Local File Inclusion), or other web attacks if the server is not hardened.

. Mitigation steps:

1. Apply proper access control (e.g., `.htaccess`, server config) to restrict public access to directories like `/CVS/`, `/vendor/`, and `/secured/`.
2. Ensure **directory listing is disabled** in the web server settings to prevent users from seeing the contents of folders.
3. Delete development folders like `/CVS/` and unused

scripts that shouldn't be on a production server.

4. For files like index.php, ensure proper coding practices to avoid file inclusion or injection vulnerabilities.

5. Use intrusion detection systems (IDS) and access logs to **detect scanning attempts** and repeated unauthorized access.

Resources used:

Linux operating system and gobuster tool.

Task-3

Make a login in the website <http://testphp.vulnweb.com/> and intercept the network traffic using wireshark and find the credentials that were transferred through the network.

❖ **Attack name:** Network sniffing

❖ **Severity:** High

Reason: Network sniffing is highly severe because it can reveal sensitive information such as passwords and personal data, breach privacy, exploit network weaknesses, disrupt regular operations, and the result in legal and compliance complications.

❖ **Steps to reproduce with screen shots:**

Step 1: Launching Wireshark:

Launch Wireshark from the Applications menu or terminal.

Select your **active network interface**. In my case, it was enp0s3. Make sure you have the necessary permissions and select the appropriate network interface to capture the data.

Step 2: Attempting to login:

Once we initiate packet capturing with Wireshark, we will navigate to the website

<http://testphp.vulnweb.com/login.php> . After reaching the login credentials and attempt to log in. This process will allow us to capture the packets that are transmitted during the login identity any potential vulnerabilities or security weaknesses in the authentication process.

Capturing from enp0s3

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

Apply a display filter ... <Ctrl-/>

Time	Source	Destination	Protocol	Length	Info
2.608966373	142.250.193.138	10.0.2.15	TLSv1.3	8694	Application Data, Application Data
2.608984892	10.0.2.15	142.250.193.138	TCP	54	53698 → 443 [ACK] Seq=2574
2.609010408	142.250.193.138	10.0.2.15	TCP	4374	443 → 53698 [ACK] Seq=3542
2.609030745	10.0.2.15	142.250.193.138	TCP	54	53698 → 443 [ACK] Seq=2574
2.609041731	142.250.193.138	10.0.2.15	TCP	1494	443 → 53698 [ACK] Seq=3547
2.609125703	142.250.193.138	10.0.2.15	TCP	2542	443 → 53698 [PSH, ACK] Seq=3547
2.609132648	10.0.2.15	142.250.193.138	TCP	54	53698 → 443 [ACK] Seq=2574
2.610052409	142.250.193.138	10.0.2.15	TLSv1.3	7254	Application Data, Application Data
2.610094681	10.0.2.15	142.250.193.138	TCP	54	53698 → 443 [ACK] Seq=2574
2.610097751	142.250.193.138	10.0.2.15	TCP	11574	443 → 53698 [ACK] Seq=3558
2.610130812	10.0.2.15	142.250.193.138	TCP	54	53698 → 443 [ACK] Seq=2574
2.610168220	142.250.193.138	10.0.2.15	TLSv1.3	9574	Application Data, Application Data
2.610177374	10.0.2.15	142.250.193.138	TCP	54	53698 → 443 [ACK] Seq=2574
2.610400865	142.250.193.138	10.0.2.15	TCP	4374	443 → 53698 [ACK] Seq=3579
2.610410273	10.0.2.15	142.250.193.138	TCP	54	53698 → 443 [ACK] Seq=2574
2.610464042	142.250.193.138	10.0.2.15	TLSv1.3	5814	Application Data, Application Data

Frame 1: 100 bytes on wire (800 bits), 100 bytes captured (800 b) on interface enp0s3

Ethernet II, Src: PCSSystemtec_c9:dd:3d (08:00:27:c9:dd:3d), Dst: 10.0.2.15

Internet Protocol Version 4, Src: 10.0.2.15, Dst: 10.0.2.3

User Datagram Protocol, Src Port: 34074, Dst Port: 53

Domain Name System (query)

0000 52 55 0a 00 02 03 08 00

0010 00 56 9a 34 00 00 40 10

0020 02 03 85 1a 00 35 00 40

0030 00 00 00 00 00 01 12 00

0040 69 74 79 2d 63 68 65 60

0050 03 63 6f 6d 00 00 01 00

0060 00 00 00 00

enp0s3: <live capture in progress> Packets: 7069

Step 3: Stop!!

← → ↻ Not Secure http://testphp.vulnweb.com/login.php

acunetix acu art

TEST and Demonstration site for **Acunetix Web Vulnerability Scanner**

[home](#) | [categories](#) | [artists](#) | [disclaimer](#) | [your cart](#) | [guestbook](#) | [AJAX Demo](#)

search art

[Browse categories](#)
[Browse artists](#)
[Your cart](#)
[Signup](#)
[Your profile](#)
[Our guestbook](#)
[AJAX Demo](#)

Links
[Security art](#)
[PHP scanner](#)
[PHP vuln help](#)
[Fractal Explorer](#)

If you are already registered please enter your login information below:

Username :
Password :

You can also [signup here](#).
Signup disabled. Please use the username **test** and the password **test**.

[About Us](#) | [Privacy Policy](#) | [Contact Us](#) | ©2019 Acunetix Ltd

After, we have captured the necessary packets, we will stop the process in the wireshark. This will allow us to analyze the recorded data.

Analysis:

Wireshark has captured numerous packets, but we are specifically interested in the HTTP packets. To filter these out, we can use the display filter option within Wireshark. By entering “http” in the filter section, we can isolate and view all the captured relevant traffic and ignore the rest.

After that , I found the actual packet of that login credentials attempt, you can see in figure

Here are the results:

The image shows a Wireshark packet capture window. The top menu bar includes File, Edit, View, Go, Capture, Analyze, Statistics, Telephony, Wireless, Tools, and Help. Below the menu is a toolbar with various icons. A filter bar at the top displays the expression `http.request.method == "POST"`. The packet list pane shows two packets:

No.	Time	Source	Destination	Protocol	Length	Info
1399	67.827320254	10.0.2.15	44.228.249.3	HTTP	591	POST
1457	83.540168275	10.0.2.15	44.228.249.3	HTTP	591	POST

The packet details pane for packet 1399 is expanded, showing the following layers:

- Frame 1399: 591 bytes on wire (4728 bits), 5
- Ethernet II, Src: PCSSystemtec_c9:dd:3d (08:
- Internet Protocol Version 4, Src: 10.0.2.15,
- Transmission Control Protocol, Src Port: 408
- Hypertext Transfer Protocol
- HTML Form URL Encoded: application/x-www-for

The packet bytes pane shows the raw data in hexadecimal and ASCII format. The status bar at the bottom indicates: `wireshark_enp0s3BJXAA3.pcapng`, Packets: 1688 · Displayed: 2 (0.1%) · Dropped: 0 (0.0%)

Warning: This is not a real shop. This is an example PHP application, which is intentionally vulnerable to web attacks. It is intended to help you test Acunetix. It also helps you understand how developer errors and bad configuration may let someone break into your website. You can use it to test other tools and your manual hacking skills as well. Tip: Look for potential SQL Injections, Cross-site Scripting (XSS), and Cross-site Request Forgery (CSRF), and more.

❖ **Impact:**

1. If login credentials are exposed in network traffic, unauthorized individuals could easily intercept and use them to gain access to user accounts.
2. If the credentials be linked to accounts with financial information, attackers could misuse them to commit financial fraud, which could involve unauthorized transactions or accessing sensitive financial data.
3. Attackers can use the captured credentials to log in to user accounts, potentially leading to unauthorized access, data theft, and misuse of personal information.
4. Exposing login credentials puts user privacy at risk by giving attackers access to personal information, messages, and sensitive data connected to the accounts.

❖ **Mitigation steps:**

1. Make certain that all communications between the client
2. Encryption ensures that credentials are not sent in plain text, thus protecting them exposure.
3. Adding an extra layer of security with MFA can help protect accounts even if credentials are compromised.
4. Consistently keep an eye on network traffic to identify any unusual activities or unauthorized access attempts. Use intrusion detection systems (IDS) to help spot potential threats.
5. Keep all systems, software and applications up to date with the latest security patches to prevent the vulnerabilities that could be exploited.

❖ **Resources used:**

Linux operating system ,Wireshark tool and Firefox browser.

